

# BRS07\_Configuración de dispositivos y sistemas informáticos II.

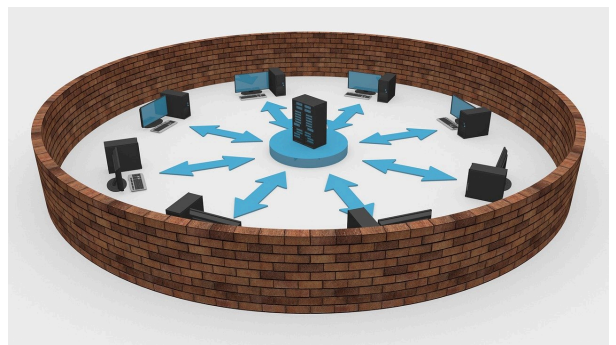
---

## Configuración de dispositivos y sistemas informáticos II.

---

### Caso práctico

En la empresa ACME SL desde hace unos días no paran de recibir incidentes de seguridad en el SOC. De todos ellos hay dos urgentes que deben resolver. Uno relacionado con una denegación de servicio distribuido y otro relacionado con un ataque a la web de la compañía.



[pixabay](#) (Dominio público)

Sus administradores y analistas de seguridad están analizando la información recopilada del incidente de DDoS (Denegación de Servicio Distribuida). El objetivo es buscar desde qué ISPs viene el ataque para informar a nuestro SOC, y se puedan tomar las acciones oportunas con los ISP del país sobre las IPs detectadas. La finalidad de todo ello es aplicar las contramedidas necesarias y disminuir el impacto del ataque.

En los siguientes puntos iremos estudiando materias que tienen que ver con el servicio de vigilancia de un sistema como es el servicio de monitorización, el almacenamiento de la información de monitorización (logs) y el SIEM. Ya que están directamente relacionados con los servicios que presta un SOC y que servirá para gestionar incidentes y detectar problemas de configuración relacionados con la seguridad.

Otra de la materias que trataremos será la configuración de dispositivos perimetrales como son los firewall, los routers y los proxy. Ya que nos ayudarán en la defensa de los ataques que impactan en la disponibilidad: DoS y DDoS.



Ministerio de Educación y Formación  
Profesional (Dominio público)

Materiales formativos de FP Online propiedad del Ministerio de Educación y Formación  
Profesional.

[Aviso Legal](#)

# 1.- Seguridad del puesto de trabajo y endpoint fijo y móvil.

## AntiAPT, Antimalware.

---

### Caso práctico

Los atacantes han recopilado información de los usuarios de la empresa que son administradores del sistema para intentar atacar sus equipos, ya que saben que son los que tienen privilegios en la red. De esta manera los atacantes pueden evitar tener que escalar privilegios en el ataque. El método que va a utilizar es infectar páginas web de descargas de software de administración: MobaXterm, putty, OpenVnc,...



EOI (Dominio público)

¿Por qué es útil tener mecanismos de defensa en los puestos de trabajo? ¿Se debe incrementar esta protección en los puestos de administración?.

#### Cuidado Administrador

Los mecanismos de defensa en los equipos de usuarios son uno de las primeras líneas de defensa, que puede prevenir el acceso inicial de los atacantes al sistema. Bien por descarga de malware escondido en aplicaciones gratuitas, correos electrónicos, navegación a páginas web infectadas,...

Los usuarios con permisos de administración deberían estar más vigilados y tener mecanismos de protección y detección de amenazas por el impacto que tienen en sus cuentas en el sistema.

## Seguridad del puesto de trabajo y endpoint fijo y móvil.

### AntiAPT, Antimalware

Los puestos de trabajo o puestos de clientes son el punto más débil de la seguridad de un sistema, ya que son los operados por los usuarios y los que más errores de seguridad comenten si la compañía no dispone de un nivel de concienciación adecuada sobre la seguridad. Por lo que están siendo el principal objetivo de los atacantes.

Inicialmente estas zonas estaban más desprotegidas al no considerarse críticas, pero con el crecimiento del número de incidentes, se descubrió que eran las más vulnerables para el acceso inicial al sistema.

Se ha producido en los últimos años un cambio de paradigma en la seguridad. Protegiendo los **equipos finales de los sistemas (endpoint)**, equipos de los usuarios, en lugar de proteger únicamente los servidores que es dónde se almacenaba la información.

Los equipos de los usuarios son los que elevan el riesgo del sistema ya que son los que se conectan a páginas web, descargan archivos, reciben correo,... Es otro de los motivos por los que proteger los equipos de los usuarios, disminuirá el riesgo de sufrir un incidente de seguridad. Muchos de los ataques requieren de acciones de los usuarios, aunque no sean conscientes de la realización de las acciones, por lo que sus acciones son necesarias muchas veces para que se produzcan las infecciones. Aquí entra también en juego la **ingeniería social**.

Si analizamos a información de los múltiples ataques realizados a los sistemas, muchos de ellos tienen su origen en los equipos finales del sistema, y a través de escalado se privilegian los atacantes se hacen con el control de los puntos más críticos del sistema. Por lo que es importante no dejar desprotegidos los puntos finales de los sistemas y protegerlos con medidas de seguridad.



EOI (Dominio público)

Una de los mecanismos de protección de los equipos de los usuarios finales son los **endpoint**, Estos endpoints tienen capacidad de configuración y permiten desplegar una serie de reglas para la detección de nuevas amenazas. Además de tener la capacidad de remitir la información de lo que está sucediendo en el equipo a un servidor central, para que dicha información sea enviada al SOC y analizada por los equipos de respuesta a incidentes o también por el equipo de [threat hunting](#).

Existen actualmente varios modelos de software libre que tiene la capacidad de incluir reglas de detección, así como realizar consultas a los clientes (por ejemplo: [osquery](#)). Esto es bastante efectivo cuando se quieren tener información actual ante un incidente de seguridad.

Esta medida de protección permite tener información real sobre las máquinas, incluso recopilar información actual y actualizada en el momento del análisis del incidente, lo que permita recopilar información que no está siendo enviada o analizada por el SOC.

Las herramientas antiAPT están más orientadas a poder reaccionar de manera autónoma ante un incidente o ciertos IOCs, de manera que el tiempo de reacción disminuya ([dwell time](#)). Ya que a pesar de lo múltiples mecanismos de seguridad que se implanten en el sistema debemos tener en cuenta un eficiente mecanismo de reacción ante incidentes. Las herramientas antiAPT se irán actualizando con la inteligencia de amenazas que proporciona el departamento de [threat intelligence](#).

En el siguiente video podemos visualizar la importancia de la [inteligencia de amenazas](#).

## 2.- Seguridad del correo electrónico.

---

### Caso práctico

El correo electrónico es uno de los principales vectores de entrada en los ataques. Aprovechándose de la ingeniería social, muchos de los usuarios de los sistemas descargan adjuntos, acceden a enlaces de páginas web infectadas, introducen información personal sensible como claves, ... Por lo tanto es necesario establecer mecanismos de seguridad que nos permitan contrarrestar los fallos de seguridad de los usuarios.



**Suplantan al Ministerio de Sanidad con la excusa de 'una dosis extra de la vacuna contra el COVID-19'**

INCIBE (Dominio público)

Vamos a identificar mecanismos de seguridad que configuraríamos para los usuarios en el servidor de correo.

Correo seguro

- Establece listas blancas de dominios confiables
- No permitas correos con adjuntos ejecutables.

- Alerta con los avisos y campañas de phishing para configurar reglas temporales asociados a campañas
- No permitas ficheros comprimidos con contraseñas. Hay campañas que utilizan este método para evadir los mecanismos de análisis.

Visita la web de [Actualidad de la OSI](#) y determina alguna regla más.

## Seguridad del correo electrónico

Las principales amenazas del correo electrónico son la entrada de malware a través de:

- Enlaces maliciosos en el cuerpo del mensaje.
- Documentos adjuntos en el correo.
- Campañas de desinformación.

Frente a estas amenazas los mecanismos de protección son:

- Protección del servidor de correo frente a enlaces maliciosos.
- Protección del servidor de correo frente a ficheros que contengan malware.
- Limitación al reenvío automático de correos que nos proteja de la fuga de información.
- Concienciación y formación de ciberseguridad a los usuarios.

Hay 3 protocolos principales que gestionan la entrada y salida de correos electrónicos:

- SMTP (Simple Mail Transfer Protocol) – Para el envío de correos.
- POP3 (Post Office Protocol) – Realiza la transferencia de correos entre el cliente y el servidor de correo electrónico. Los mensajes son eliminados una vez que son descargados en el dispositivo a no ser que se indique que se guarden en el servidor. Una vez descargado el mensaje no requiere conexión a Internet.
- IMAP (Internet Message Access Protocol) – Realiza la transferencia de correos entre el servidor de correo electrónico y el cliente. Los mensajes pueden ser transferidos a múltiples dispositivos porque se guardan en el servidor.

De cara a tener una configuración segura del servicio de correo, la información tiene que estar cifrada en tránsito. A continuación indicamos los puertos más comunes de funcionamiento de los protocolos de correo electrónico:

| <b>PROTOCOLO (entrada)</b> | <b>PUERTO (TCP)</b> | <b>CIFRADO</b> |
|----------------------------|---------------------|----------------|
| IMAP                       | 993                 | SSL            |
| POP3                       | 995                 | SSL            |
| IMAP                       | 143                 | NO             |
| POP3                       | 110                 | NO             |
| <b>PROTOCOLO (salida)</b>  | <b>PUERTO (TCP)</b> | <b>CIFRADO</b> |
| SMTP                       | 465                 | SSL            |
| SMTP                       | 587                 | NO             |
| SMTP/STARTTLS              | 587                 | TLS            |
| SMTP                       | 25                  | NO             |

Héctor Fernández Bardal. *Puerto asociados al correo electrónico*  
(Dominio público)

También se debe tener en cuenta el acceso a los servicios de webmail sobre HTTPS, para que siga existiendo el cifrado de la información de la información del servicio en tránsito.

De cara poder implantar mecanismos de protección y seguridad en el correo electrónico, es importante conocer cada uno de los campos de un mail. Por lo que a continuación os adjuntamos las siguientes referencias:

- [INCIBE - Campos de un correo.](#)
- [Cabeceras de un correo](#)

Con el objetivo de aplicar reglas de seguridad asociadas al correo y poder analizar los campos del correo electrónico que permitan implementar reglas que minimizan los riesgos de que los usuarios sean infectados al recibir campañas fraudulentas de correo que contengan:

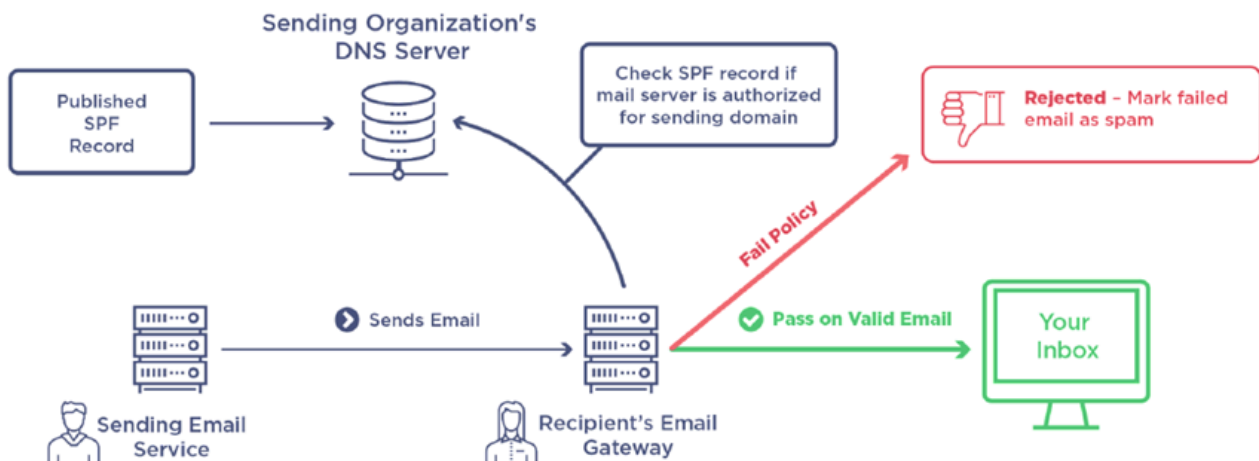
- Ficheros adjuntos maliciosos: ficheros ofimáticos con macros, ficheros ejecutables enmascarados.
- Remitentes de dominios maliciosos
- Enlaces maliciosos
- Ficheros comprimidos con contraseña, para evitar el análisis por las herramientas de seguridad (antivirus)
- Cabeceras de seguridad del correo electrónico.

A continuación se indicarán protocolos que nos permitirán aumentar la seguridad para proteger la suplantación del correo electrónico y añadir funcionalidades de autenticación:



## SPF (Sender Policy Framework).

Nos permite proteger el correo contra falsificaciones de remitentes. Los propietarios de los dominios registran en el DNS los servidores de correos desde los que realizan los envíos. Eso sirve para que el resto de los usuarios que reciban un correo puedan consultar estos servidores SMTP autorizados a través de los servidores DNS, identificando las máquinas por su dirección IP.



Javier Mir (Dominio público)

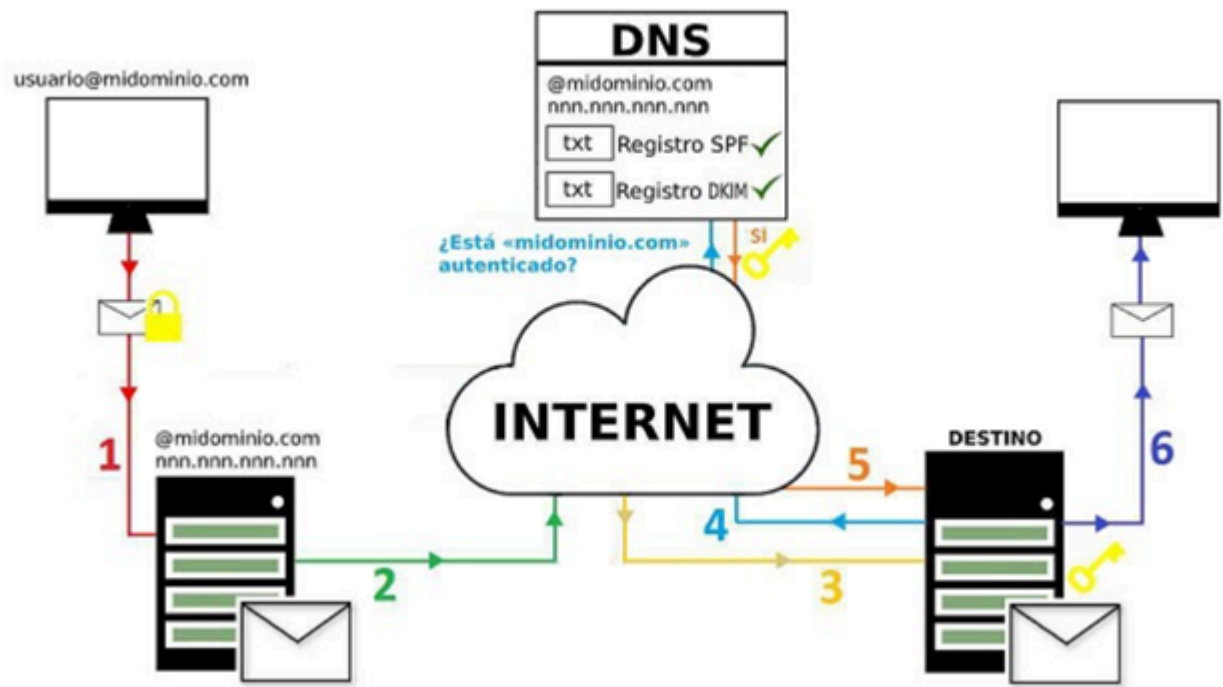
Aunque este sistema puede ser menos eficiente para el reenvío de correos, ya que el mensaje puede viajar entre diferentes dominios y sería necesario mantener esa lista de dominios desde los que se permite el reenvío.

Se debería configurar el SPF en [modo monitor](#).

## DKIM (Domain Keys Identified Mail)

Otra forma de autenticar un correo añadiendo un texto cifrado difícilmente falseable que contiene la procedencia del mensaje. Esta información es validada en destino con mecanismos de clave público/privada que confirman la autenticidad y la integridad.

Las claves públicas que necesitan los destinatarios para realizar estas comprobaciones se almacenan en los registros de los servidores DNS.



INCIBE (Dominio público)

## DMARC (Domain-based Message Authentication Reporting, & Conformance)

Suma los beneficios de SPF y DKIM

Todos estos mecanismos de protección no son suficientemente eficientes por sí solos, ya que los usuarios juegan un papel muy importante en la seguridad de un sistema. Ya que si no tenemos estos mecanismos técnicos alineados con el nivel de concienciación de los usuarios, a veces no son válidos.

## Autoevaluación

¿En qué protocolo nos apoyamos para darle seguridad al servicio de correo electrónico?

- ☐ NTP
- ☐ DNS
- ☐ HTTP

Incorrecto. Es un protocolo ligado a sincronización de tiempos

Correcto. El protocolo de resolución de nombres nos permitirá identificar los dominios asociados a campañas de envíos de correos electrónicos maliciosos o de SPAM

Incorrecto. Protocolo de navegación. No se utilizara en los protocolos DMARC, DKIM, SPF

Solución

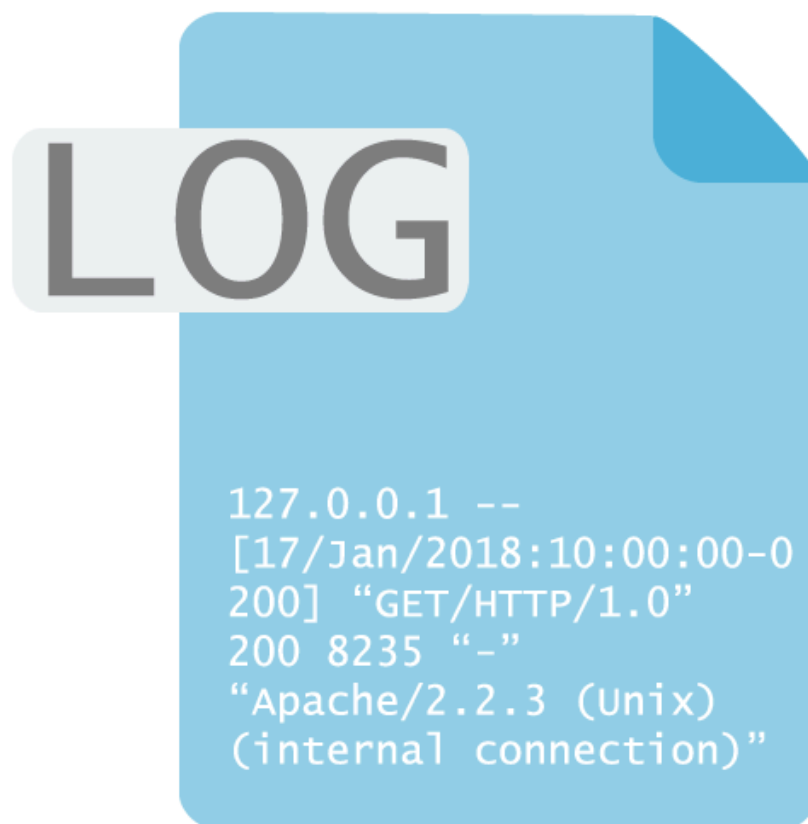
1. Incorrecto
2. Opción correcta
3. Incorrecto

### 3.- Herramientas de almacenamiento de logs.

---

#### Caso práctico

Almacenar los registros(logs) de lo que sucede en el sistema es un mecanismo que permite proteger los sistemas y mejorarlos. Tiene un coste asociado porque es necesario proveer al sistema de infraestructura del almacenamiento de la información y así como el procesamiento y análisis de dicha información. Esta información ha crecido exponencialmente con los años debido a requisitos legales y el cumplimiento de marcos (frameworks) y sistemas de gestión de la seguridad de la información. Pero tienen un beneficio mayor ya que nos permiten mejorar la seguridad y nos previene de ataques con más impacto.



Vamos a establecer un cálculo del dimensionamiento de la infraestructura de almacenamiento de logs, para la fuente de información del firewall perimetral. Cada log ocupa 500 bytes y se de media 2000 eventos por segundo.

### Almacenamiento de Logs

$(2000 \text{ eventos por segundo} * 86400 \text{ segundos del día}) * 20 \text{ días} * 500 \text{ bytes} = 2592 \text{ GB}$   
de almacenamiento mensual

Como vemos es importante elegir bien las fuentes y la información que llega al sistema para no consumir recursos ineficientemente.

## Herramientas de almacenamiento de logs

Los logs nos permiten realizar las tareas de vigilancia para evitar los incidentes (monitorización). Estos logs están almacenados en los equipos que los generan, pero deben enviarse a un sistema centralizado que obtiene información de diferentes fuentes:

- Sistemas operativos
- Aplicaciones
- Bases de datos
- Herramientas de seguridad: antivirus, NIDS, HIDS,
- Dispositivos de red: switches, firewalls, NAC, ...

El almacenamiento centralizado de logs además permitirá utilizar otras herramientas de apoyo con tecnologías como el Big Data que permitirán encontrar patrones de comportamientos anómalos.

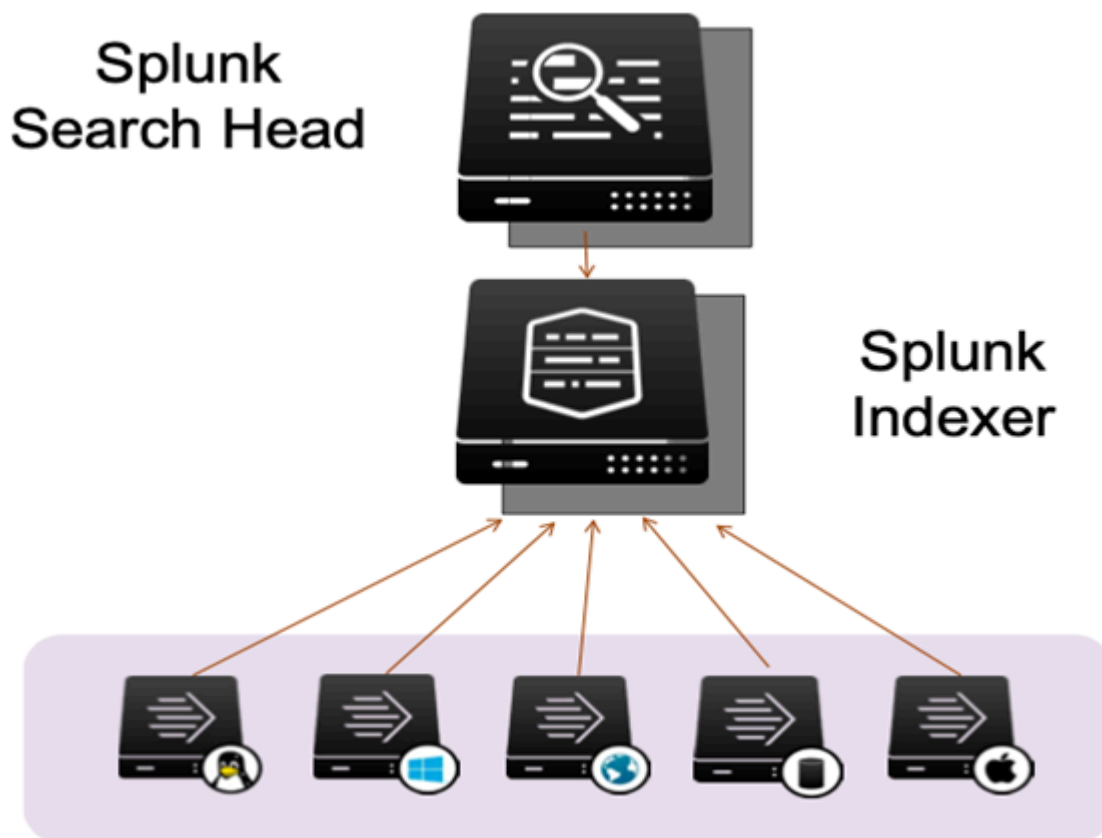
Uno de los problemas a los que se enfrentan las herramientas que almacenan log son:

- Incremento de la información recibida
- Incremento del número de ataques y la duración del ataque en el tiempo, que obligan al sistema a tener mayor capacidad de retención

- La regulación que obliga al almacenamiento de los registros (logs) para utilizarlos como evidencias.

En conclusión es como buscar “una aguja en un pajar”, cuando el pajar cada vez en más grande y la aguja va cambiando forma.

Algunas de las herramientas más extendidas actualmente son: [Logstash](#), [GrayLog](#),... Lo que se impide a las nuevas herramientas, al tener un volumen muy alto de información, es tener la capacidad de localizar información con indexación de manera eficiente. Una de las herramientas que se ha popularizado en el mercado gracias a esta características es [Splunk](#).



[krytonsolid](#) (Dominio público)

Splunk no fue creada para utilizarse en el mundo de la seguridad, pero su capacidad de búsqueda y análisis de datos, etc. permite realizar ciertas tareas en la búsqueda de información que son importantes en los procesos de un SOC:

- Mejora en la búsqueda de datos para la detección de amenazas
- Agilidad en las tareas de investigación
- Cortos tiempos de respuesta en la búsquedas de gran volumen de datos

A continuación describimos los elementos más importantes de la arquitectura de Splunk que permiten buscar y almacenar logs. En esta arquitectura el “Splunk Indexer” es el responsable de:

- Procesa los logs y los almacena con índices para facilitar su análisis y búsqueda
- Existe una organización eficiente de índices que permiten hacer eficiente la herramienta

El camino que recorre un registro hasta que es almacenado en disco es:

- Recopilación de la fuente
- Envío al punto central de recogida de información
- Parseo
- Indexado
- Almacenamiento en disco



Sam Bowne (Dominio público)

En relación al almacenamiento de logs en los sistemas operativos más comunes se apoya en las siguientes herramientas: en Windows la herramienta que almacena los logs es el EventViewer y en Linux la herramienta que almacena y gestiona los logs es el servicio de syslog.

Se deben establecer en ambos las políticas de seguridad que permiten almacenar los logs tanto en los equipos como en un sistema centralizado. En los equipos deben guardarse logs con una menor retención, pero que evite la pérdida de información en caso de no poder enviar la información al servicio centralizado SOC.

De cara a que cada vez la información que necesitamos para investigar un incidente es mayor, es necesario establecer la arquitectura de monitorización: red de monitorización, almacenamiento y procesamiento de la información. La información que proporcionan los logs relativos al sistema tienen un carácter sensible, ya que en los logs se almacena mucha información y a veces con un alto nivel de detalle acerca de los dispositivos, configuraciones,

protocolos, ... dependiendo del nivel que hayamos configurados (verbose). Por lo que esta información tiene que se enviada y tratada con seguridad.

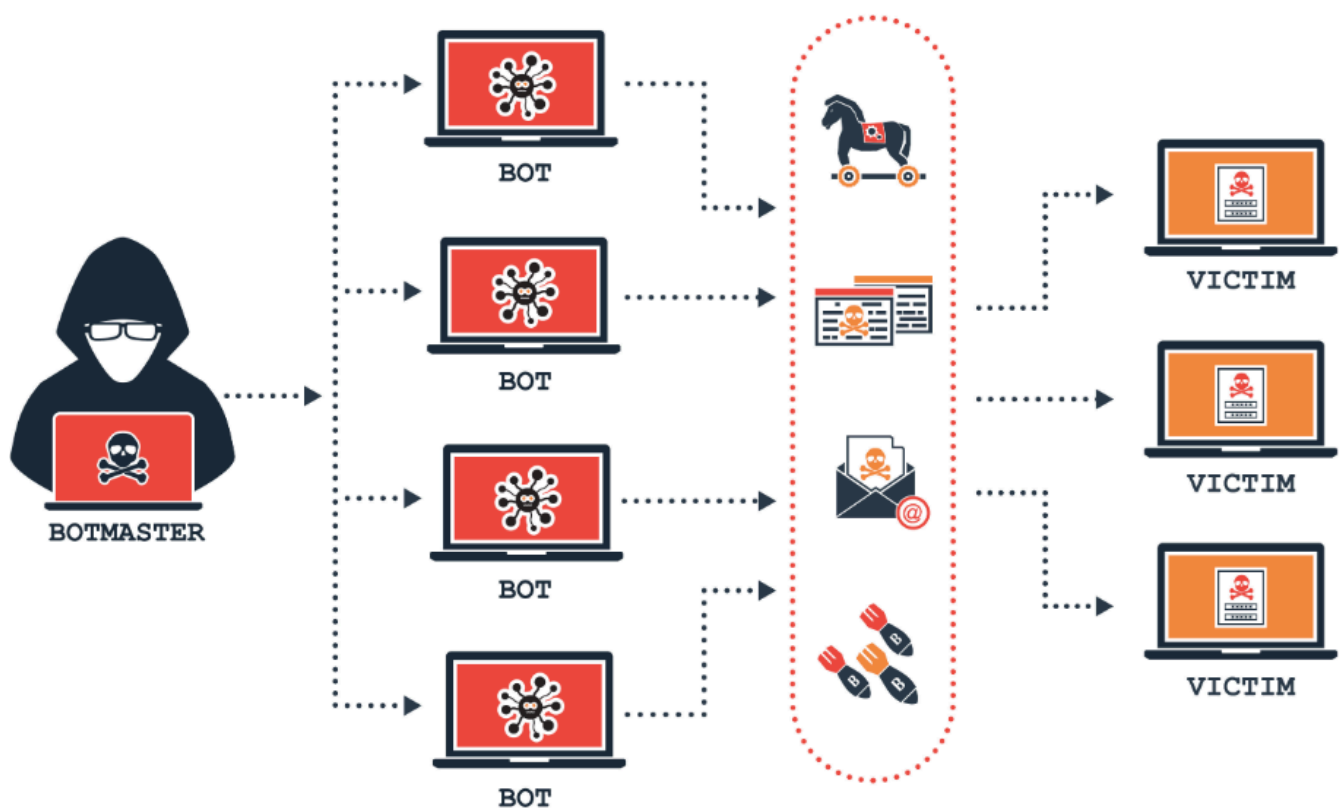
El almacenamiento logs es una de las tareas de SOC. Algunas herramientas almacenan los logs posteriormente a su tratamiento y otras los almacenan con anterioridad. Un log no tiene un volumen de ocupación alta, sobretodo en modo "raw", pero sí que el aumento del número de estos logs hace que las dimensiones de almacenamiento de logs dependan del número de equipos y de las fuentes que se vayan a monitorizar.



## 4.- Protección ante ataques de denegación de servicio distribuido (DDoS).

### Caso práctico

Cada vez son de mayores dimensiones los ataques de DoS y DDoS por la capacidad que tienen los atacantes de ir aumentando su infraestructura desde la que realizan el ataque en base a Bots. Incluso el ataque se hace desde diferentes países y localizaciones que dificulta la mitigación y medidas de protección frente al ataque.



INCIBE - OSI (Dominio público)

Para poder realizar una protección frente a los ataques de DoS/DDoS debemos articular medidas de protección no sólo técnicas sino también procedimentales. Una opción es subcontratar el servicio de protección de denegación de servicio a través de empresas especializadas. Además, deberás tener documentados los procedimientos de activación de

defensa de este tipo de ataques poniéndote en comunicación con los ISPs desde los que se realiza el ataque, o desde tu ISP para que filtren el tráfico y mitiguen la dimensión del ataque.

## Protección ante ataques de denegación de servicio distribuido

### (DDoS)

La disponibilidad de los servicios afecta a una de las tres dimensiones de la seguridad. La mayoría de los servicios que una compañía ofrece a sus clientes, están publicados en las DMZ. Estos servicios están protegidos por dispositivos de protección perimetral que evitan que el servicio se vea interrumpido. Además de la pérdida de servicio y las sanciones asociadas al incumplimiento de los SLA.

La protección frente a ataques de denegación de servicios se debe dimensionar acorde a un estudio de volumen de tráfico esperado. Además de aplicar las configuraciones asociadas a la protección de esta amenaza.

Los primeros mecanismos que afrontan los medios técnicos para la defensa de esta amenaza son los dispositivos de protección perimetral. Por lo que se deben establecer alarmas en dichos dispositivos que permitan tomar las primeras acciones de mitigación. Estas acciones tienen que estar documentadas en los procedimientos de defensa ante los ataques, para que la reacción al ataque sea lo más eficiente posible.



EOI (Dominio público)

Además de las acciones de defensa de nuestra infraestructura contra ataques externos, se debe proteger los ataques realizados desde nuestra infraestructura por una mala configuración, o por la utilización de nuestro sistema de una manera fraudulenta ante el aviso de otra organización u organismo. Para estos casos también debemos poner los mecanismo de protección necesarios, para que no podamos dañar otros sistemas frente ataque no controlados que se realizan desde nuestro sistema.

Los ataques de [DoS y DDoS](#) son mitigados por los firewalls y routers perimetrales, aunque dependiendo de la magnitud del ataque puede que estos no tengan la capacidad de contrarestarlo. Empresas especializadas en ciberseguridad ofrecen este servicio de manera externalizada, ya que ciertos ataques de DDoS requieren de una infraestructura potente y unos conocimientos muy específicos en la materia.

Algunos de los ataque más comunes de DoS son:

- **Syn Flood:** su método se basa en utilizar el método de apertura de [conexión TCP en 3 pasos](#) (3-way-handshake), dejando sin terminar el último paso (envío ACK por parte del cliente) y por lo tanto quedando el servidor a la espera y consumiendo recursos. Con la herramienta hping podremos simular este tipo de ataques: `hping --syn --flood --rand-source -p <Port> <IP-Adresse>`
- **Connection Flood:** Consiste en realizar un elevado número de peticiones sobre un servicio.
- **UDP Flood:** Consiste en realizar un elevado número de peticiones sobre el protocolo UDP. Ya que cada vez que un equipo envía una petición al puerto UDP cerrado, el servidor responde con un paquete ICMP del tipo destino inalcanzable. Para que el atacante pueda destinar sus recursos a enviar paquetes UDP sin tener que gestionar los ICMP recibidos, utiliza IPs falsas.

Una medida preventiva y alineada con los mecanismos de prevención es poder obtener información previa ante posibles ataques. Ya que los grupos de ciberdelincuentes previamente preparan su infraestructura de Botnes para lanzar los ataques.

Algunas medidas de protección contra Syn Flood son:

- Aumentar los recursos asociados a las conexiones semiabiertas. No es efectivo si la dimensión del ataque supera los recursos del dispositivo. Reciclaje de la conexión TCP semiabierta más antigua

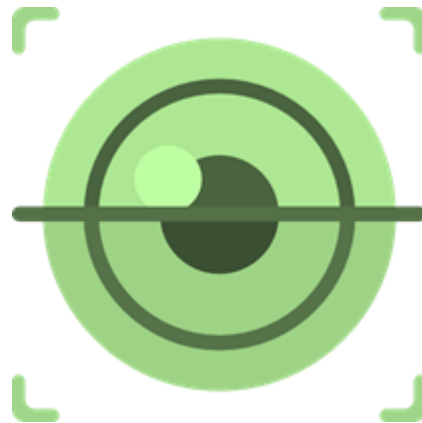
- Establecer una cola LIFO en los recursos asociados a las conexiones semiabiertas. De tal manera que la última conexión será la primera en liberarse ante un determinado número de conexiones.
- Almacenar menos información sobre el establecimiento de la conexión. TBC mínimo.
- Servicio de un proveedor externo basado en la nube debido al aumento de los bots y sus dimensiones. La idea de los proveedores es tener una infraestructura que permita distribuir la carga del ataque.

## 5.- Configuración segura de cortafuegos, enrutadores y proxies.

---

### Caso práctico

El router lleva muchos años funcionando perfectamente en la empresa en la que Alejandro es el administrador de la red. Con la llegada del nuevo responsable de tecnologías a la empresa quiere que se revise la configuración desde el punto de vista de la seguridad.



EOI (Dominio público)

Podemos ayudar Alejandro a qué debería mirar en el firewall. Si quieres acercarlo a un caso específico entra en la web de un fabricante y mira el comando que te ayudaría a configurarlo.

#### Configuración del router

- El firmware del router está actualizado
- Se ha eliminado las contraseñas por defecto
- Se han deshabilitado los protocolos de enrutamiento que no se utilizan
- Deshabilitar los puerto sin uso y asignados a una VLAN específica.

- Activación auditoría. Envío auditoría a servidor externo.
- Cambio VLAN por defecto para ciertos protocolos
- Arranque seguro
- La red de administración y de operación están separadas
- Las contraseñas del equipos se almacenan cifradas
- Eliminación de protocolos inseguros.

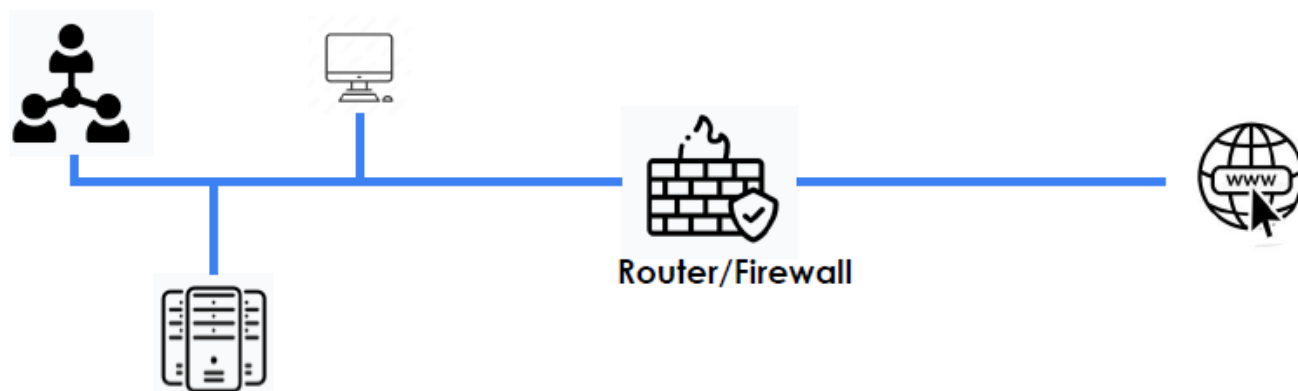
## Configuración segura de cortafuegos, enrutadores y proxies

Abordaremos en este capítulo, la configuración de tres de los principales dispositivos de protección perimetral de las redes y sistemas. Todas la tareas de configuración de estos dispositivos tienen el objetivo de proteger estos dispositivos en sí mismo así como de la redes y sistemas que los albergan.

A continuación se detallan cada uno de los aspectos a considerar en la configuración segura estos dispositivos, que puede ser aplicado para cualquier elemento del sistema.:

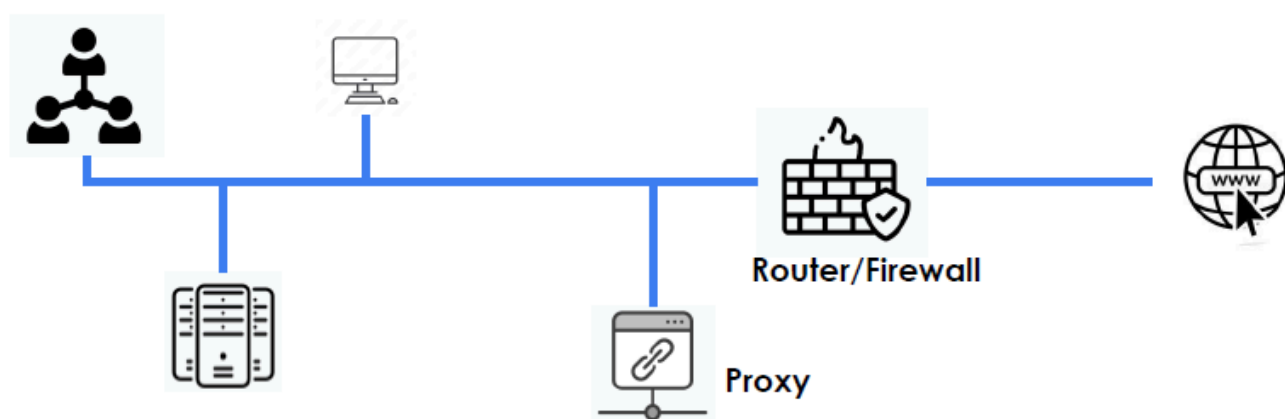
- Control de acceso
- Autenticación
- Control de sesión
- Configuración de servicios
- Mantenimiento
- Certificación de seguridad del producto.
- Auditoría
- Gestión de eventos.
- Protección de las comunicaciones

También debemos saber que estos dispositivos se pueden colocar en cualquier parte de la red para separar zonas, pero están en las zonas más perimetrales que se conectan con las redes de menos confianza para la compañía. A continuación se muestra un diseño de una red con el componente de un firewall/router.



Héctor Fernández Bardal. *Red con router firewall* ([CC0](#))

En la siguiente imagen se puede visualizar un diseño de una red con un firewall, router y proxy.



Héctor Fernández Bardal. *Red con Firewall router y proxy* ([CC0](#))

En los siguiente apartados iremos detallando la configuración de seguridad de cada uno de los dispositivos.

## Autoevaluación

¿Sólo es necesario tener un firewall para defender perimetralmente una red?



☐ Verdadero ☐ Falso

### Falso

Antiguamente los sistemas sólo se basaban en este dispositivo de protección perimetral. Pero la complementación con otros medios de protección como proxy, también permite que controlemos la navegación de nuestros usuarios internos y de las conexiones que realizan.

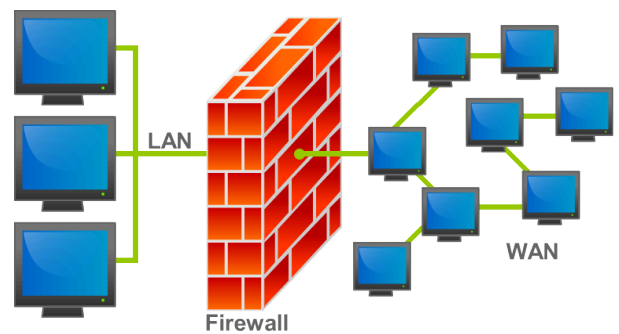


## 5.1.- Firewalls.

---

### Firewalls

Los firewall han evolucionado desde los simples dispositivos perimetrales en las redes, en los que sólo había uno y separaba la parte interna a la parte externa, a los firewall en nube donde este cambio de paradigma ha permitido difuminar el perímetro y controlar los flujos de información hacia servicios alojados fuera de nuestras instalaciones.



Bruno Pedrozo (CC BY-SA)

En la integración de la red IT y OT también cobran un papel importante el firewall, para separar estas dos redes de la empresa que ahora se integran. Donde la red OT es una red más crítica y de más importancia que la red IT y por lo tanto tiene que estar protegida por estos dispositivos.

En este apartado ampliaremos la información relativa a los firewalls debido a la importancia que tienen como dispositivo de defensa. Estos dispositivos nos ayudarán a:

- Impedirá obtener información de los sistemas y de los puertos que están abiertos y cerrados la capas más internas de la red.
- Proteger y realizan el control de acceso a IP internas y puertos.
- Controlar los flujos de información de entrada y de salida de las distintas redes del sistema.
- Las reglas de los firewalls asociadas a los flujos de salida impedirán a los dispositivos conectarse contra IPs y dominios maliciosos
- No permitirán tener un mayor conocimiento de la red, a través del análisis de la información que recogen.
- Constituye el dispositivo principal de protección de la defensa en profundidad basado en capas.
- Permite reducir y mantener controlada la exposición de tu sistema frente ataques.

El firewall será uno de los puntos críticos del sistema ya que estará expuesto frente a las amenazas externas. Por lo que las vulnerabilidades de estos dispositivos son críticas y

constituyen un elemento crítico de parcheo.

Otro de los firewall que existen en la red, son los **firewall locales** de software que residen en los equipos. El objetivo de aplicar medidas de protección a los firewalls locales de los equipos es complementar la seguridad de los firewall de red. Controlando la entrada de protocolos en los equipos. ¿Para qué necesitamos abrir un protocolo en el firewall de un equipo si no necesitamos que esté habilitado ese servicio?. Por lo tanto debemos activar el firewall de los equipos para aumentar el control de las comunicaciones

La administración de los dispositivos es un punto muy importante desde el punto de vista de la seguridad, ya que si el acceso con permisos de administración a los dispositivos fuese vulnerado tendría un alto impacto en el sistema, por lo que se debe realizar desde dispositivos controlados, apoyado por la segmentación.

La medidas generales de bastionado de estos dispositivos es:

- Mantener el software actualizado. Estos equipos debe estar entre los prioritarios para su actualización al ser un punto crítico del sistema.
- Segmentación de acceso para los administradores. Filtrando el acceso para ciertos equipos.
- Habilita el doble factor de autenticación para los administradores del firewall,
- Elimina las contraseñas y usuarios por defecto del dispositivo.
- Eliminar los servicios de administración administración no confiables.
- Realzar auditorías de seguridad sobre el firewall

## Autoevaluación

¿Qué amenazas nos ayuda a detectar un firewall tradicional?

- ☐ Virus
- ☐ Phishing
- ☐ Enlaces con IPs maliciosas

Incorrecto. Los firewalls tradicionales no tienen capacidades de análisis de de ficheros. Los NGFW sí se pueden añadir estas capacidades.

Incorrecto. El firewall no puede analizar la información que viene en los correos electrónicos.

Correcto. Los firewalls pueden monitorizar todas las conexiones que se realizan y la información que se obtiene es de la capa 3 y 4 donde están el campo IP.

#### Solución

1. Incorrecto
2. Incorrecto
3. Opción correcta

## 5.1.1.- Medidas de evasión.

---

### Medidas de evasión de antivirus

Una vez hayamos configurado el firewall, debemos realizar una auditoría de seguridad que nos permita saber que el equipo está bastionado correctamente al nivel de seguridad que deseamos. Se puede realizar una auditoría manual del dispositivo o combinarla con scripts que automaticen parte del proceso. La herramienta nmap nos permitirá realizar todas estas tareas.



Cathie (Dominio público)

Las pruebas son para intentar evadir las medidas de seguridad del firewall modificando:

- MAC/IP a través de métodos de MAC/IP spoofing. Para las tareas de IP spoofing podemos utilizar modificadores el comando nmap "señuelos" (-D), proxy (--proxies) y spoofing (-S). En el caso de MAC spoofing se realizará con --spoof-mac, pero hay que tener en cuenta

que para este ataque tenemos que utilizar una MAC de la red en la que estoy conectado, a no ser que nuestro único objetivo sea ocultar el ataque en lugar de capturar el tráfico.

- La fragmentacion, MTU, y longitud de los datos. La fragmentación de paquetes servirá para aquellos firewalls que no analizan el paquete entero para aquellos comunicaciones en las que los paquetes están fragmentados. Los paquete se pueden fragmentar con la opción -f, -ff o en base a la [MTU](#) que será múltiplo de 8 (-mtu). Otra opción es fijar la longitud de la capa TCP con datos aleatorios una vez que hemos introducido los datos en la capa (--data-length).
- Cabeceras de los campos. Estableciendo específicamente TTL(--ttl) o checksum (--badsum) inválidos nos pueden dar información del sistema auditar ya que cada sistema responde de una manera diferente.

## 5.2.- Router.

---

### Routers

Los router son dispositivos que trabaja en la capa 3 (red) del modelo OSI. Se encargan de realizar el control de la comunicaciones en una red. Es un elemento fundamental para interconectar redes. Con el objetivo de aislar dispositivos y crear capas dentro de un sistema, estos dispositivos constituyen un elemento de la red que permite aislar determinadas zonas.

También tienen la capacidad de crear reglas que permitan o denieguen el tráfico entre dos zonas, mediante listas de control de acceso (ACL). Al ser un dispositivo de control, es un elemento crítico en la seguridad, por lo que la configuración del dispositivo es una tarea necesaria para mantener el sistema securizado.



Pixabay (Dominio público)

Estas son las medidas de configuración segura que debemos aplicar a:

- Deshabilitar los puertos que no se utilicen que formen parte una VLAN específica de "puertos sin uso".
- Deshabilitar los servicios de un router que no se utilicen como: BOOTP, CDP, FTP, TFTP, HTTP, DNS, ...
- Utiliza las versiones seguras de los protocolos como por ejemplo SNMP v3 o HTTPS.
- Elimina los usuarios y contraseñas por defecto.
- Establece grupos de usuarios con diferentes perfiles, administrador, operador, monitorización,...
- El acceso remoto a los sistema debe ser con mínimo privilegio.
- Sólo permitir protocolos seguros de conexión remota como SSH2
- Establecer políticas de password complejas alineadas con las del resto de la compañía
- Restringe el acceso al equipo desde el segmento específico de administración y para determinados IP/equipos.

- Activa la auditoría (login) en el dispositivo y configúralo para que pueda enviar la información al SOC, para que pueda vigilar los comportamientos anómalos.
- Establece un tiempo de inactividad de las sesiones de administrador.
- Las password almacenadas en el dispositivo estarán cifradas.
- Limita el número de intentos en la autenticación, con el fin de evitar los ataques de fuerza bruta.
- Mantén actualizado el software del dispositivo.
- Incluye al dispositivo en el procedimiento de copias de seguridad. Realizando copias de seguridad de la configuración de manera periódica, para poder recuperara la operatividad del dispositivo de manera rápida en caso de desastre.
- Habilitar únicamente los protocolos de enrutamiento que se estén utilizando.

[SNMP](#) es un protocolo de recopilación de información acerca del dispositivo. Existen diferentes herramientas que permiten auditar la configuración de este protocolo utilizado en los router. Como son [smpcheck](#), [snmpwalk](#), [snmpget](#), [módulos específicos de metasploit](#) (snmp-scan),...

## Autoevaluación

Administrarías el firewall de tu sistema a través de la web que viene por defecto es totalmente seguro.

☐ Verdadero    ☐ Falso

### Falso

Normalmente la administración vía web HTTP es inseguro, mejor HTTPS, porque el protocolo no está cifrado. Estos servicios suele tener la autenticación de usuario y contraseña por defecto y no tiene posibilidad de configurar todas las opciones de seguridad que tiene el dispositivo. Además habría que analizar si el servicio web no tiene vulnerabilidades.

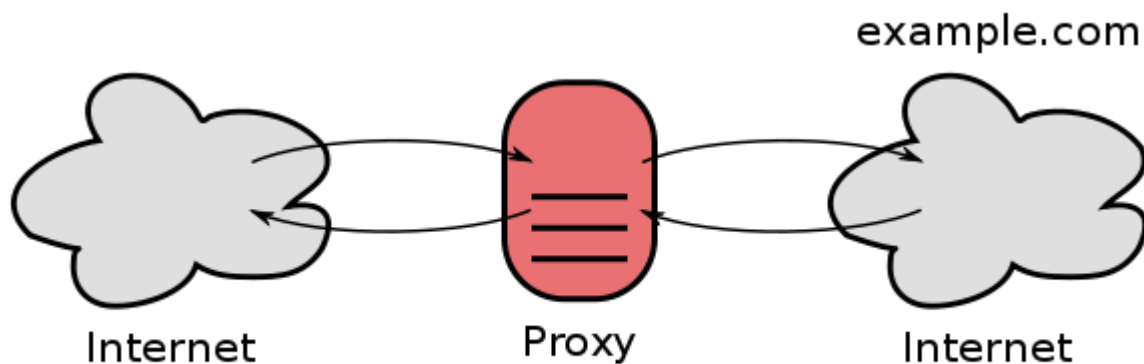
Busca una protocolo de gestión cifrado y seguro como ssh.

## 5.3.- Proxy.

---

### Proxy

Un proxy es un dispositivo colocado entre los equipos de nuestra red e Internet. Este dispositivo intermedio permite analizar el tráfico intercambiado y en base a reglas definidas permitir o no la conexión. Además este dispositivo es el que identifica el servidor al que nos conectamos como solicitante, lo que permite anonimizar al solicitante original. Se trata de un dispositivo que trabaja a nivel de aplicación. Los proxies pueden trabajar específicamente con diferentes protocolos: SNMP, POP, POP3, FTP, HTTP,...



H2g2bob (Dominio público)

Existe 2 tipos de arquitecturas para este servicio.

- Disponer de un proxy central al que se conectan todos los usuarios de la red. Esto permite tener una política común para toda la compañía.
- Externalizar el servicio hacia un proveedor que controle este componente de la seguridad de nuestro sistema. Son los denominados proxy en nube.

Desde el punto de vista de la seguridad proporcionan control , anonimización y vigilancia de las conexiones.

Muchos de los proxies tiene capacidades para incluir listas de IOCs en sus dispositivos con el objetivo de impedir la conexión contra estas IPs y dominios.



Una de las características que debemos activar en el proxy es la vigilancia del dispositivo, integrando la información que se recoge en el dispositivo con el centro de operaciones de seguridad (SOC).

## 6.- Monitorización de sistemas y dispositivos.

---

### Caso práctico

Los administradores del servidor se ha quejado al director de seguridad por el bloqueo de PowerShell en el entorno. Después de varias reuniones finalmente se aprobó el uso de PowerShell en el entorno. Ahora se necesita vigilar su uso para saber cómo se está utilizando. Durante un mes se investiga si se detecta algún evento sospechosos que relacionado con la activación.



Héctor Fernández Bardal (Dominio público)

Identifica el ID que visualiza evento de powershell que pueden detectar su uso.

Referencia:<https://www.eventsentry.com/blog/2018/01/powershell-pw3rh311-detecting-preventing-powershell-attacks.html>

Powershell

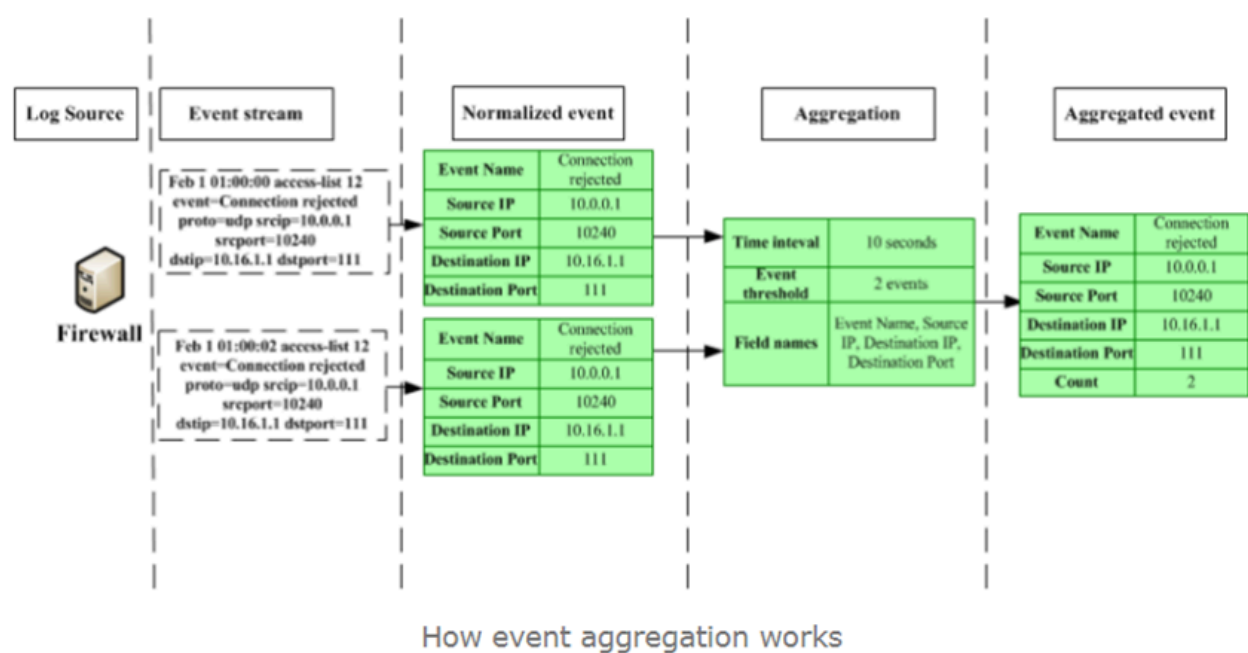
ID de evento Evento 400 y 800 para el Event Viewer de Windows.

Monitorización de sistemas y dispositivos.

çLa monitorización del sistema debe de estar dimensionada a los recursos que se destinen a esta tarea, ya que no por tener más dispositivos monitorizados es más efectivo, si no se dispone de personal que permita tratar las alertas y la inforamación.

Muchos de los sistemas de monitorización están automatizando el tratamiento de los incidentes más comunes a través de los [SOAR](#).

La primera tarea de la monitorización de sistemas consiste en la configuración de los dispositivos y software para que realice un registro de las actividades realizadas y que permita detectar actividades maliciosas e intrusiones. Todas las fuentes de información pueden proporcionar información relativa a la seguridad, pero los dispositivos relacionados con la seguridad son las que aportan información más específica. Por lo que debemos centrarnos en estos dispositivos. Ejemplo. Configuración de "[logging](#)" en un firewall de Checkpoint.



[Vladimir Potapov](#) (Dominio público)

Debemos tener en cuenta que los dispositivos de seguridad de nuestro sistema son los que están más directamente relacionados con la información más relevante y crítica de seguridad, ya que son dispositivos de control hacia los elementos más críticos.

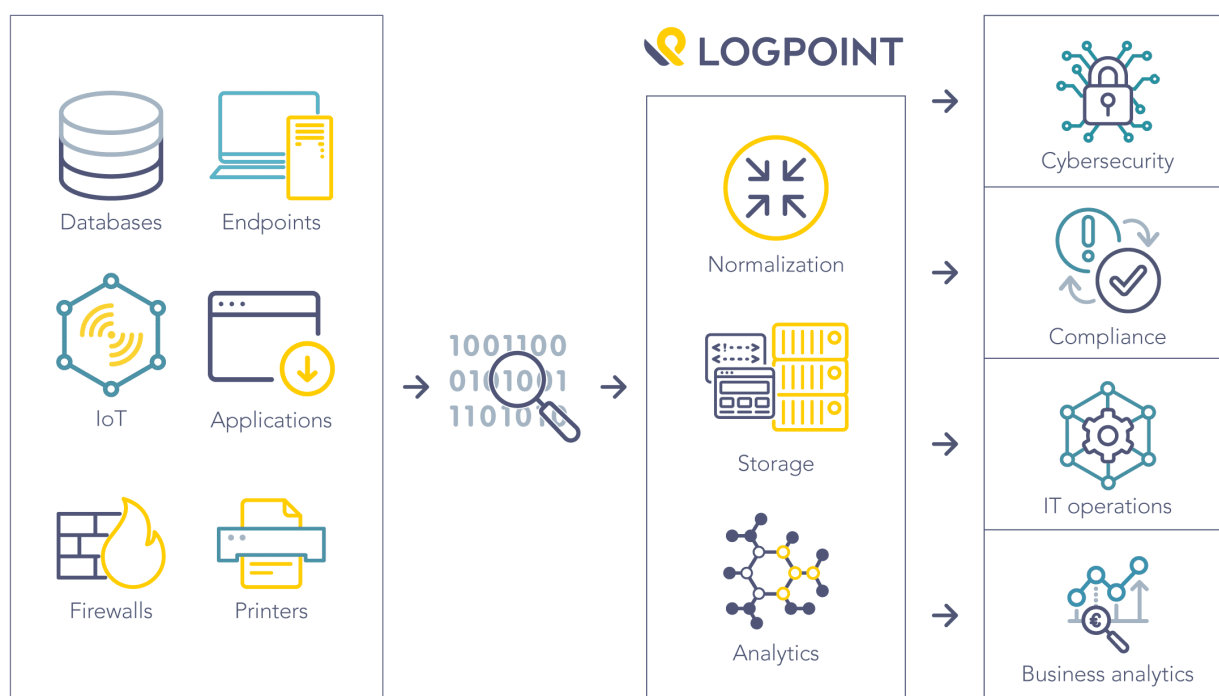
Tradicionalmente la monitorización se centraba sólo en los dispositivos más críticos, pero actualmente lo que se intenta es abordar los incidentes para su detección en una fase más

temprana de la Kill-Chain de los atacantes, por lo que el concepto de EDR ha cobrado mucha importancia a la hora de poder reaccionar y resolver un incidente de manera rápida. Por lo que la monitorización y la búsqueda de artefactos están recayendo en estas herramientas y es uno de los requisitos de bastionado de la red, que se pueda activar la monitorización de los elementos del sistema.

Los sistemas de monitorización también tienen que estar configurados de manera segura, ya que los atacantes intentarán desactivar estos mecanismos para que los métodos de defensa se desactiven y no permitir que la información de seguridad llegue al SOC y los equipos DFIR puedan responder al ataque. Por lo tanto se establecerán reglas de detección de la desactivación de la monitorización o la falta de información usual de la misma.

A continuación se muestra una imagen con las múltiples fuentes de información que podría tener un SIEM, para que fueran tratadas a través de la correlación y obtener de ese proceso las alertas y avisos de seguridad.

## SIEM at a glance



logpoint (Dominio público)



## 7.- SIEMs.

---

### Caso práctico

Un equipo de SOC utiliza como herramienta un SIEM para monitorizar el sistema de amenazas. Como analista de seguridad tenemos que aprender a priorizar los incidentes según su criticidad. Empezando por los niveles más críticos a los más bajos. Las herramientas de monitorización correctamente configuradas nos facilitan las tareas de reducir las amenazas a detectarlas y gestionarlas en menos tiempo.

Los analistas de seguridad juegan un papel muy importante en la investigación de incidentes, analizando y comprendiendo cómo funciona el ataque y cómo pararlo. Durante la investigación, como analistas tenemos que preguntarnos el ¿Cómo? ¿Cuándo? ¿por qué? y encontrar las respuestas dentro de los logs.



b-secure. *Analista SOC* (Dominio público)

¿Qué acciones tomarías para mejorar la resolución de una alerta?

Haz uso de tu experiencia y utiliza herramientas que te ayuden analizar los datos (IA, Big Data). En cada incidente ayuda a entender el funcionamiento de la red, y apóyate en la documentación del sistema.

Propón mejoras para que no se vuelvan a producir los incidentes o falsos positivos.

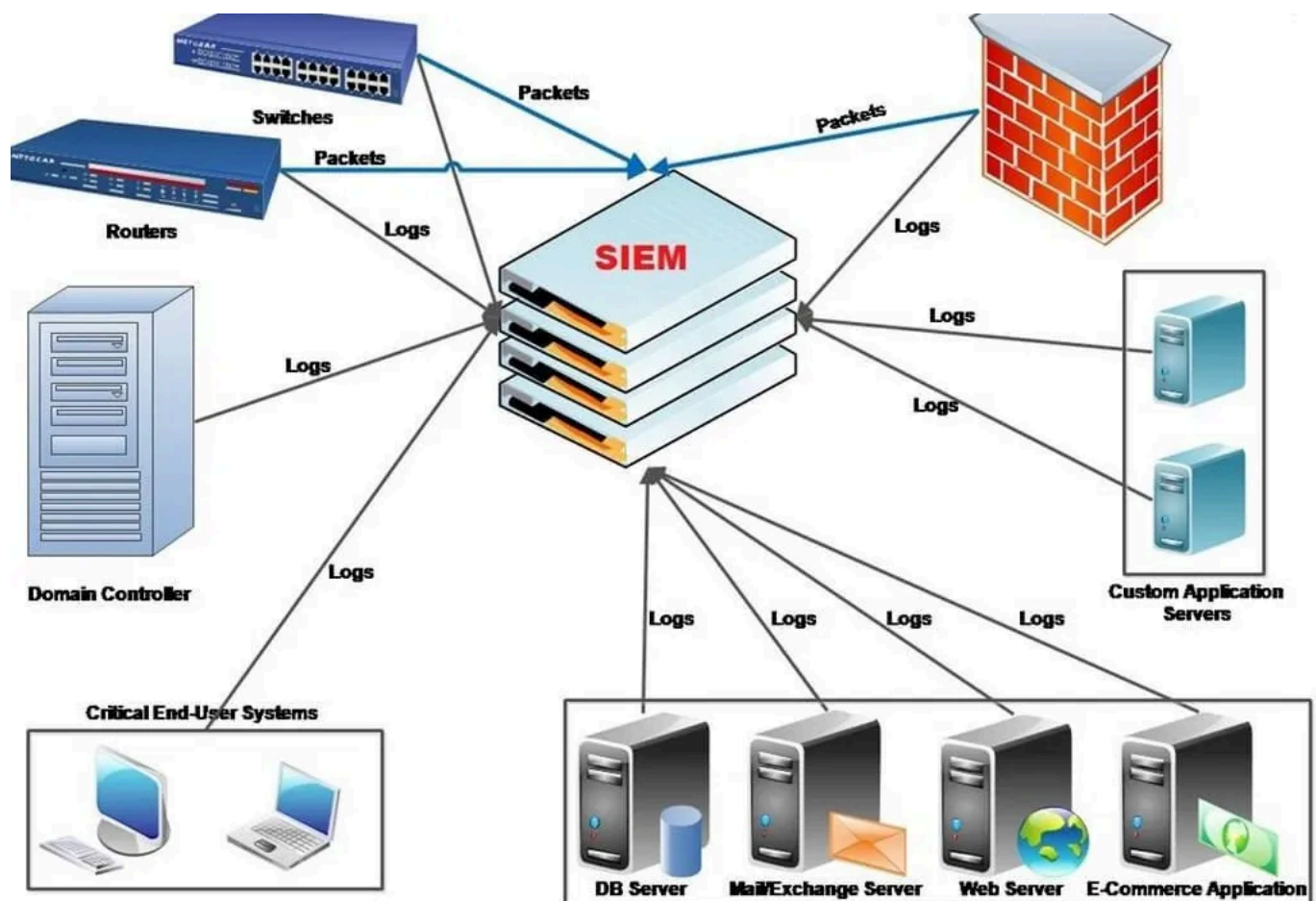
## SIEMs

Un SIEM es un dispositivo que recoge información de diversas fuentes de manera centralizada y que relaciona esta información de las diferentes fuentes para detectar anomalías de seguridad en el sistema: usuarios que inician sesión desde IPs no conocidas, fuera de horario, desde dos IPs distintas en un corto periodo de tiempo (viaje imposible),....

El SIEM está en continua aprendizaje y mejora, por lo que muchas veces se detectan anomalías que en realidad son comportamientos legítimos, en ese caso es necesario implementar las excepciones para que este "falso positivo" no se vuelva a producir, ya que este tipo de evento consumen recursos de nuestro servicio de SOC que podríamos destina a eventos que realmente tienen importancia.

Por lo tanto, el SIEM es el dispositivo central del SOC que recopila toda la información de las diferentes fuentes y en base a reglas de seguridad y análisis de la información, proporciona alertas de seguridad.

Este método de seguridad es reactivo y ante estas alertas de seguridad se debe establecer el procedimiento de actuación en base a los SOP (Security Operation Playbook).



[gbhackers.com](http://gbhackers.com) (Dominio público)

Dentro del ciclo de gestión de incidentes, las fases que tiene que ver directamente con el SIEM son:

1. Dentro de la fase de configuración de los dispositivos de seguridad de nuestra infraestructura: antivirus, EDR, proxy, firewalls, IDS / IPS, etc, debemos configurar la auditoría de estos dispositivos para que puedan enviar información al SIEM. También tendremos que aplicar al SIEM las reglas de detección de amenazas acorde al contexto de nuestra organización.
2. En la fase de detección gestionaremos las alertas de seguridad y realizaremos las investigaciones que sean necesarias para encontrar el origen de la alerta.
3. Una vez que se ha resuelto el ataque aplicaremos las lecciones aprendidas a la mejora del sistema y que el ataque vuelva a ocurrir otra vez. Esto nos permitirá indicar a los administradores del sistema si necesitamos mejorar las vulnerabilidades del sistema para aplicar nuevas medidas de configuración segura o disponer de más recursos económicos y humanos.



Existen diferentes productos en el mercado que nos permiten implementar nuestro SIEM en el sistema. Algunos de estos productos son de libre distribución y requieren de un mantenimiento y actualización por parte del personal interno de la organización, aunque también existe la posibilidad de adquirir un producto con licencia que tenga el apoyo y soporte de un equipo externo especializado.

- [SIEM recomendados por CCN](#)
- [SELKS](#)
- [Splunk](#)
- [Security Onion](#)
- [Elastic SIEM](#)

Muchas empresas de ciberseguridad están ofreciendo este servicio a la empresas para que puedan externalizarlo y delegar la detección de amenazas a empresas especializadas. Aunque es necesario la implicación de la empresa en los mecanismos de reacción cuando se produce un incidente, de tal manera que los protocolos de actuación permitan detener el ataque.

## 8.- Soluciones de Centros de Operación de Red, y Centros de Seguridad de Red: NOCs y SOC's.

### Caso práctico

En los últimos años y a medida que los ciclos de desarrollo se hecho más complejos y el software evoluciona en ciclos tecnológicos más cortos se acumulan errores funcionales y fallos de seguridad, muchos sin resolver. Los administradores acumulan tareas y presión y se genera desconfianza con el software y sus dispositivos. Esta presión acaba en las personas y las fricciones entre los equipos de IT y seguridad.

La resolución de problemas de seguridad de los dispositivos se ha convertido en la causa principal de incidentes de seguridad.



Thales. Centro de operaciones (Dominio público)

Delimitar las tareas del equipo de seguridad y los operadores de equipos no ayudar a repartir las tareas asociadas a la seguridad y eliminar fricciones.

Vamos a llevarnos bien

Debemos establecer una matriz de responsabilidades donde la operación del dispositivo debe ser responsabilidad NOC. El NOC es el responsable de recoger la información que ayude de operaciones y proporcionar información al SOC para ayudarlo en la seguridad. Las indicaciones precisas de lo que se debe hacer ante un incidente de seguridad son del SOC. Ademñás, cuando existe un incidente de seguridad el SOC debe establecer las prioridades, pero estas acciones no deben tomarse sobre la marcha, sino que tienen que ser entrenadas previamente en ejercicios de simulación.

## Soluciones de Centros de Operación de Red, y Centros de

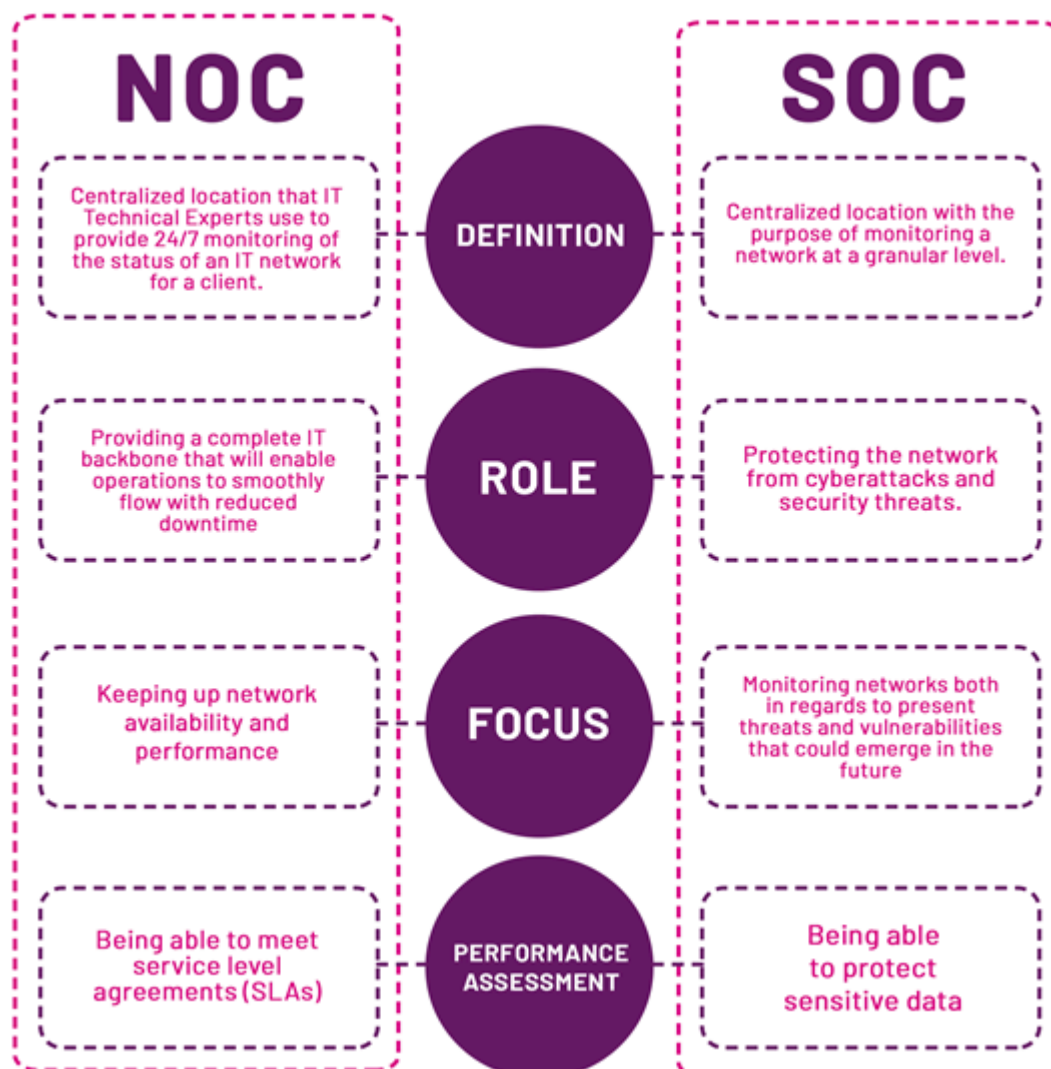
### Seguridad de Red: NOCs y SOC

Una vez implementados las medidas de seguridad preventivas para los sistemas, las tareas de seguridad no finalizan en este punto, sino que requieren de un mantenimiento y mejora continua. Esto se logra con tareas de mejora y revisión de la seguridad de manera periódica. Pero otro de los pilares básicos de la seguridad es la vigilancia de dichos sistemas. Esto se logra con la monitorización de los sistemas.

Debido al incremento de sistemas y de información que recopilamos a cerca de su funcionamiento y uso. Se crean los centros de operaciones de seguridad (SOC o CyOC). Son centro con servicios relativos a la seguridad que suelen operara en tiempos de 24x7 o 8x5, dependiendo de la criticidad del sistema y de los recursos que podamos invertir.

El otro centro de control de las operaciones del sistema es el Network Operation Center (NOC) que se encarga de gestionar la disponibilidad de la red. Muchas de las herramientas utilizadas en el SOC y el NOC son comunes. Aunque el objetivo de su uso suele ser distinto.

La dimensión de la disponibilidad relativa a la seguridad está siendo uno de los elementos comunes entre el NOC y el SOC, de ahí que deban ser complementarios. Ej: Un incidente de DDoS. Aunque los objetivos son diferentes ya que en el NOC la prioridad es el funcionamiento, en el SOC es mantener el nivel de seguridad del sistema.



[medium.com](https://medium.com) (Dominio público)

El SOC (Centro de Operaciones de Seguridad) es una unidad centralizada y servicio interno del sistema de una organización donde se monitorizan, evalúan y defienden los sistemas de información de una empresa.

Típicamente tiene herramientas para monitorizar la red, gestionar incidentes y reaccionar ante diferentes eventos.

Estos centros tienen como misión detectar actividades anómalas que deriven en la creación y tratamientos de incidentes de seguridad, para que los sistemas no se vean dañados por las amenazas externas que deriven en fugas de información o robo, inoperatividad del sistema o destrucción de la información.

Para el funcionamiento de los SOC es necesario recopilar información de los sistemas y de la red que lo soportan. Algunos ejemplos de fuentes de información (logs) útiles que deben ser centralizados en un punto común para posteriormente darle tratamiento: logs de firewalls, logs de DNS, logs DHCP, logs de acceso al sistema,...

Toda esta información es centralizada en un único punto, y mediante herramientas como los SIEM se normalizan y se correlacionan.

El proceso de normalización conlleva a unificar todos los datos de las diferentes fuentes de información que son enviados en diferentes formatos, para posteriormente poder realizar búsqueda de anomalías en relación a los sistemas. El SIEM además puede añadir información adicional a la información recopilada por las fuente que pueda ayudar a procesas y detectar de una manera más eficiente la búsqueda de anomalías.

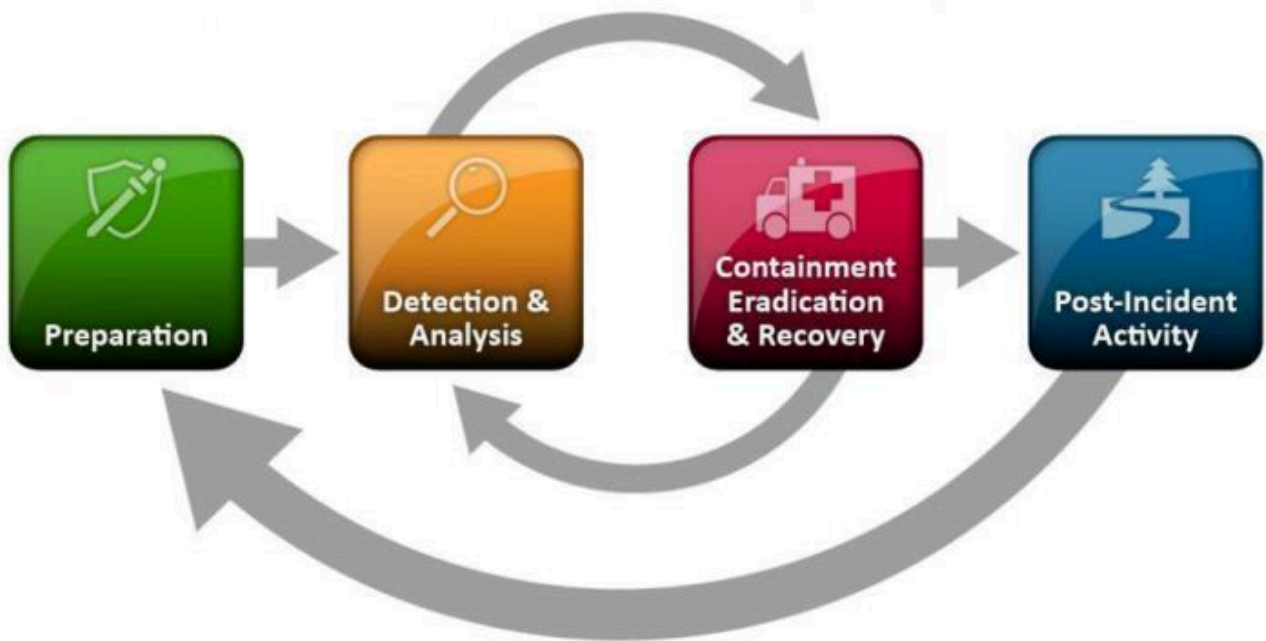
El SOC al ser un servicio de seguridad, concentra multitud de tareas:

- Gestión de registros
- Gestión de vulnerabilidades. Únicamente parte de detección y estado del sistema.
- Análisis de malware
- Threat Hunting
- Threat Intelligence (Inteligencia)
- Generación de informes técnicos y ejecutivos.
- Ejercicios de defensa.

Los integrantes del SOC son también denominados como personal del equipo de blue team.

Hay personal especializado dentro del equipo que se encarga de tareas forense, análisis de malware, threat intelligence, threat hunting,...

Las fases de una gestión de incidentes se pueden resumir en el siguiente diagrama de estados



Javier Cao (Dominio público)

### Preparación y prevención

Es la fase en la que se crea y se forma al Equipo de Respuesta a Ciberincidentes (ERC) y la utilización de herramientas y recursos necesarios, identificando y desplegando las medidas de seguridad que hayan determinado de acuerdo con un análisis de riesgos.

### Identificación

En esta fase se detectan los ciberincidentes que pueda sufrir la organización a partir de las medidas de seguridad implantadas, desencadenando procesos de notificación.

### Contención

Esta fase tiene lugar para reducir y abordar las consecuencias directas del ciberincidente de una manera rápida y efectiva impidiendo la propagación, estableciendo las acciones necesarias que permitan recoger evidencias forenses.

A través del triaje del ciberincidente se evalúa la importancia e impacto en base a la información de la que se dispone en dicho momento. Además, se contempla el proceso para realizar la comunicación interna y externa sobre este tipo de ataques.

### Mitigación

El propósito de esta fase es la eliminación del incidente. Esta fase se compone de acciones inmediatas como desconexiones, controles de acceso, revisiones, etc.; y de acciones a posteriori como gestión de actualizaciones, cambios de infraestructura, etc.

### **Recuperación**

Devolver a la normalidad los sistemas afectados para retomar la actividad priorizando los sistemas más críticos para el negocio y, aplicar las medidas de seguridad que eviten la repetición del ciberincidente. Además, se establece cómo debe ser la comunicación para la vuelta a la normalidad de los afectados.

### **Post-Incidente**

Se lleva a cabo el proceso de registro de todo el ciberincidente: trazabilidad, escalado y notificación, actuaciones y lecciones aprendidas.

La gestión de incidentes permitirá realizar una mejora en el proceso de monitorización de sistema ante nuevos ataques.